

PLAYBOOK

Playbook, belirli bir olay türü (örneğin brute force alarmı) geldiğinde izlenecek adımların önceden, sırayla yazılmış hali. Analist olay anında sıfırdan düşünmek yerine bu listeyi takip eder.

Neden gerekli, sezgi neden yetmez?:

- Olay anında zaman baskısı var; sezgiyle hareket etmek adım atlamaya yol açabilir.
- Farklı analistler aynı olayı farklı kalitede/sırada çözebilir; playbook bu tutarsızlığı azaltır.
- Kritik bir adımın (kanıt saklama, containment gibi) unutulmasının bedeli ağır olabilir. Playbook bunu güvence altına alır.

Neden analist için önemli?: Playbook, olay müdahalesini kişiye bağlı bir beceri olmaktan çıkarıp tekrarlanabilir ve denetlenebilir bir sürece dönüştürür; ekip büyüdükçe ya da olay sayısı arttıkça bu tutarlılık kritik hale gelir.

“Şüpheli Giden Trafik Alarmı”

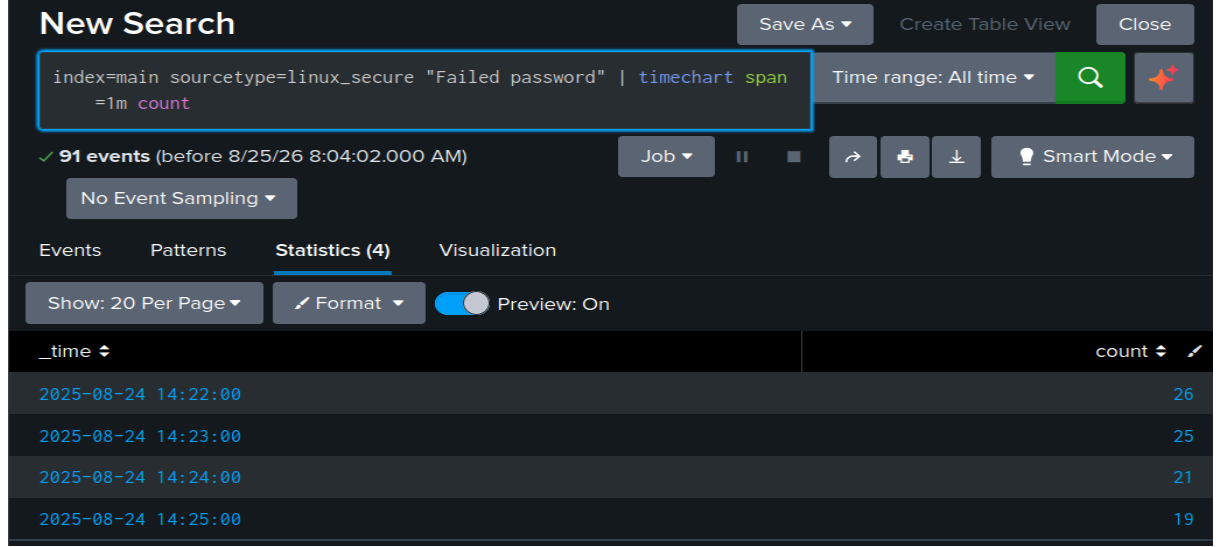
1. Alarmı tetikleyen kaynak IP ve hedef IP/port bilgisini logdan doğrula.
2. Bu IP'nin geçmişte benzer trafik üretip üretmediğini kontrol et.
3. Trafiğin yöneldiği hedefin bilinen kötü amaçlı bir adres olup olmadığını kontrol et (varsa tehdit istihbaratı/blok listesi ile).
4. İlgili host üzerinde o saatte başka anormal aktivite (yeni process, yeni bağlantı, yetkilendirme değişikliği) var mı diye bak.
5. Bulgular kötü niyetli görünüyorsa: bağlantıyı sınırla/host'u izole et, ardından olayı büyüt (containment aşamasına geç).
6. Bulgular normal görünüyorsa: sebebini not et (örneğin bilinen bir servis) ve olayı kapat.

KORELASYON İÇİN SPL

Korelasyon (correlation), farklı log kayıtları arasında bağlantı kurmak, yani birbirinden ayrı görünen olayların aslında aynı hikayenin parçaları olduğunu ortaya çıkarmaktır.

1) timechart – "Ne zaman oldu" sorusunu cevaplar

Splunk'ta stats count, tek bir sayı verir: "toplam 340 olay var" gibi. Ama bu 340 olay 2 dakikaya mı sıkışmış, yoksa 8 saate mi yayılmış, bunu bilemeyiz. timechart, zamanı dilimlere böler ve her dilimdeki sayıyı ayrı ayrı gösterir. Yani bir çizgi grafik/tablo verir.



Neden önemli?

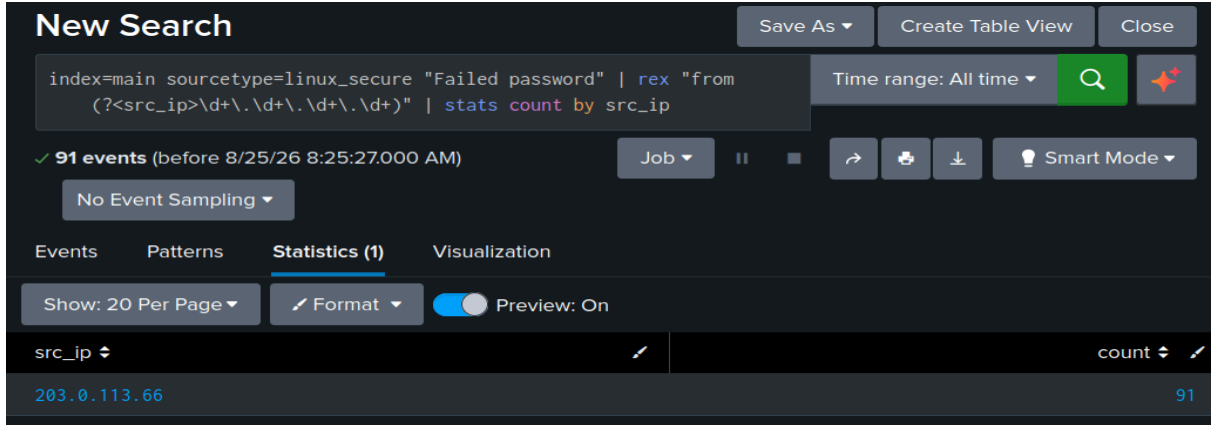
Bir insanın SSH'a şifre yazıp Enter'a basması, hatayı görüp yeniden denemesi gerçekçi olarak birkaç saniye sürer ama bunu saatlerce, dakikada 20+ kez, aralıksız yapması mümkün değil; insan yorulur, dikkati dağınık, ara verir. Burada 4 dakika boyunca sayı hiç düşmeden (26→25→21→19) sabit bir yoğunlukta devam etmesi, bunun bir script/otomasyon tarafından yapıldığını gösteriyor.

Eğer bu bilgiyi sadece stats count ile almış olsaydım, "91 başarısız deneme oldu" derdim ama bunun 91 denemenin 4 dakikaya sıkıştığını, yani saldırının hızını ve otomatik olma ihtimalini göremezdim. timechart'ın kattığı fark tam olarak bu: hacmi değil, hızı ve deseni gösteriyor. Ve pratik sonucu da önemli: bu hız/desen, bir analistin bunu "insan hatası" değil "aktif saldırı" olarak sınıflandırmasını sağlıyor. Yani Tespit ve Analiz aşamasındaki karar bu veriye dayanıyor.

2) rex – Alan yoksa kendin yaratırsın

Splunk bazı standart alanları (host, sourcetype, _time gibi) otomatik çıkarır. Ama log satırı serbest metinse (örneğin Failed password for invalid user admin from 203.0.113.66 port 43648 ssh2), Splunk bu satırın içindeki IP'yi otomatik olarak "src_ip" diye bir alan yapmaz.

rex, regex (düzenli ifade) kullanarak bu ham metnin içinden bir parçayı yakalayıp isimlendirmemizi sağlar.



New Search Save As Create Table View Close

index=main sourcetype=linux_secure "Failed password" | rex "from (?<src_ip>\\d+\\.\\d+\\.\\d+\\.\\d+)" | stats count by src_ip

Time range: All time

91 events (before 8/25/26 8:25:27.000 AM) Job

No Event Sampling

Events Patterns **Statistics (1)** Visualization

Show: 20 Per Page Format Preview: On

src_ip	count
203.0.113.66	91

Neden önemli?

Birincisi, rex olmadan bunu yapamazdım. Log satırı ham haliyle sadece metin: Failed password for invalid user admin from 203.0.113.66 port 43648 ssh2. Splunk bu satırdaki 203.0.113.66'yı otomatik olarak "alan" olarak tanımıyor. Benim için sadece bir kelime dizisi. stats count by src_ip gibi bir komut ise yalnızca tanımlı alanlar üzerinde çalışır, ham metin üzerinde çalışmaz. rex olmasaydı bu sorgu "field not found" gibi bir hata verir ya da boş dönerdi. rex, ham metni Splunk'ın anlayabileceği yapılandırılmış bir alana çevirdi.

3) Çok kaynaklı arama: İki log'u aynı anda görmek

Gerçek bir olay genelde tek bir log dosyasında görünmez. Örneğin: giriş denemesi auth.log'da, ama saldırgan giriş yaptıktan sonra yaptığı işlemler başka bir log kaynağında olabilir.

(sourcetype=A OR sourcetype=B)

Ne işe yarıyor?

Splunk'a "bana hem A kaynağındaki hem B kaynağındaki olayları getir, ikisini de tek bir sonuç listesinde, zaman sırasına göre karıştırılmış şekilde ver" diyoruz.

Neden tek başına yeterli değil?

Bu sorgu sadece iki kaynağı yan yana koyar, aralarında bir bağlantı kurmaz. Yani "A kaynağındaki bu olay ile B kaynağındaki şu olay aynı saldırıya mı ait" sorusunu cevaplamaz, sadece ikisini birlikte görmemizi sağlar. Asıl bağlantıyı kurmak için ortak bir alan (IP, kullanıcı adı gibi) üzerinden birleştirilmesi gerekir. Bu da stats by ya da transaction'ın işi.

Neden önemli?

Gerçek bir olay çoğu zaman tek bir log dosyasında baştan sona görünmez. Gerçek bir SOC ortamında SSH logları, firewall logları, EDR logları hep ayrı kaynaklardır. Bu yapı olmadan, bir analist her kaynağı ayrı ayrı arayıp sonuçları elle eşleştirmek zorunda kalır. Bu hem yavaş hem hataya açık.

4) transaction – Sorgu

The screenshot shows the Splunk Search interface with a search query: `index=main sourcetype=linux_secure ("Failed password" OR "Accepted password") | rex "from (?<src_ip>\d+\.\d+\.\d+\.\d+)" | transaction src_ip`. The search results are displayed in a table with two main groups of events.

i	Time	Event
>	8/24/25 2:22:04.000 PM	... 2 lines omitted ... Aug 24 14:22:07 web01 sshd[3004]: Failed password for invalid user admin from 203.0.113.66 port 47314 ssh2 Aug 24 14:22:09 web01 sshd[3005]: Failed password for invalid user admin from 203.0.113.66 port 43358 ssh2 Aug 24 14:22:13 web01 sshd[3006]: Failed password for invalid user admin from 203.0.113.66 port 57870 ssh2 ... 50 lines omitted ... Aug 24 14:24:12 web01 sshd[3057]: Failed password for root from 203.0.113.66 port 58394 ssh2 ... 11 lines omitted ... Aug 24 14:24:46 web01 sshd[3069]: Failed password for ubuntu from 203.0.113.66 port 52504 ssh2 Show all 92 lines host = Ubuntu source = Case1-auth.log sourcetype = linux_secure
>	8/24/25 8:03:11.000 AM	Aug 24 08:03:11 web01 sshd[1841]: Accepted password for deploy from 10.0.0.50 port 51122 ssh2 Aug 24 08:14:52 web01 sshd[1902]: Accepted password for ayse from 10.0.0.50 port 51140 ssh2 Aug 24 11:12:44 web01 sshd[2455]: Accepted password for deploy from 10.0.0.50 port 52001 ssh2 host = Ubuntu source = Case1-auth.log sourcetype = linux_secure

Grup 1 → 203.0.113.66 (saldırgan IP): "Show all 92 lines" yazıyor. Yani bu IP'ye ait 92 olay tek bir grupta toplandı. İlk olay 14:22:04, son olay (14:24:46'da gösterilen "ubuntu" denemesi ve devamında olması gereken 14:25:53'teki başarılı giriş) hepsi bu tek grubun içinde. transaction, bu IP'nin ilk temasından son eylemine kadar tüm hikayesini tek bir bloğa topladı.

Grup 2 → 10.0.0.50 (iç IP): deploy ve ayse kullanıcılarının sabah 08:03, 08:14, 11:12'deki normal, başarılı girişleri. Bunlar farklı saatlerde, birbirinden bağımsız, düzenli ofis-içi girişler.

Neden önemli?

transaction'ın yaptığı şey, veriyi otomatik olarak "kim, kiminle ilişkili" diye ayırmak. Ben tek tek bakmadan, sadece src_ip'ye göre gruplat dedim ve Splunk kendisi ayırdı:

Bir tarafta: tek bir IP'den (203.0.113.66), kısa sürede, 92 olayla gelen anormal desen.

Diğer tarafta: farklı bir IP'den (10.0.0.50), gün içine yayılmış, az sayıda, normal kullanıcı girişleri: meşru desen.

Transaction bana "bu IP'nin olayları ne kadar sürede, hangi sırayla gerçekleşti" bilgisini veriyor. Yani saldırının başlangıcından bitişine kadar tek bir olay örgüsü olarak görebiliyorum.

Zaman Çizelgesi - Case-auth.log dosyasına göre

Zaman	Kaynak	Olay	Varlık	Değerlendirme
08:03:11	auth.log	Başarılı SSH girişi	deploy@ 10.0.0.50 (iç ağ)	normal
08:14:52	auth.log	Başarılı SSH girişi	ayse @ 10.0.0.50 (iç ağ)	normal
08:21:07	auth.log	sudo apt update	ayse	normal
11:12:44	auth.log	Başarılı SSH girişi	deploy@ 10.0.0.50 (iç ağ)	normal
14:22:04	auth.log	Brute force başlangıcı	203.0.113.66 (Invalid user admin)	
14:22:04 - 14:25:52	auth.log	91 başarısız SSH girişi (7 farklı kullanıcı adı)	203.0.113.66	
14:25:53	auth.log	Başarılı SSH girişi	deploy@ 203.0.113.66 (dış IP)	anormal
14:25:54	auth.log	sudo cat /etc/shadow	deploy	credential access
14:25:58	auth.log	sudo useradd svc-update	deploy	persistence girişimi
14:26:01	auth.log	svc-update (UID=1003) oluşturuldu	sistem	